

Complete Revision Guide

Generative AI in Financial Services

MAIE 6000B Sem B, 2025–26

Based on Lectures L0–L10 and Homework 1–2

英文为主，中文对照

May 20, 2026

How to Use This Guide | 如何使用

This guide is designed for exam revision and assignment-based preparation. It summarizes the main ideas from Lectures 0–10 and integrates the likely answer patterns from Homework 1 and Homework 2.

Use it in three layers:

1. Memorize the **core definitions and comparison tables**.
2. Practise the **exam answer templates**.
3. Before the exam, review the **high-frequency questions and key sentences**.

本指南使用方式：先背核心概念和表格，再练答题模板，考前快速复习高频问题和关键英文句。

Contents

1 Course Big Picture 课程总览	3
1.1 Main Themes Across L0–L10	3
2 Lecture 0–1: Foundations of Generative AI GenAI 基础	3
2.1 What is Generative AI?	3
2.2 Traditional AI vs Generative AI vs Agentic AI	4
3 Lecture 2–3: LLMs, Prompting, RAG, and Financial Use Cases LLM、提示词、RAG 与金融应用	4
3.1 Large Language Models	4
3.2 Prompting	4
3.3 RAG: Retrieval-Augmented Generation	5
4 Lecture 4: Regulation of AI, Privacy, and More AI 监管、隐私与规则	5
4.1 Why Regulate AI in Finance?	6
4.2 OECD AI Principles	6
4.3 BIS: Why Customer-Facing GenAI is High-Risk	6
4.4 IOSCO and FSB: Capital Markets and Financial Stability	7
4.5 Hong Kong AI and GenAI Guidance	7
5 Lecture 5: Ethics and AI Governance AI 伦理与治理	8
5.1 AI Ethics vs Responsible AI	8
5.2 Responsible AI Principles	8
5.3 Fairness and Bias	9
5.4 Transparency and Explainability	9
5.5 Accountability and Governance	10

5.6	Privacy and Data Protection	10
5.7	Hallucination and Model Risk	11
6	Lecture 6: Automation vs Staff Augmentation 自动化 vs 员工增强	12
6.1	Automation vs Augmentation	12
6.2	Common Augmentation Use Cases	12
6.3	Summarization Challenge	13
7	Lecture 7: Customer Personalization 客户个性化	13
7.1	What is Customer Personalization?	13
7.2	Personalization Use Cases in Finance	13
7.3	Internal-facing vs External-facing GenAI	14
7.4	Why Use Button-Based Interfaces Instead of Free Prompt Editing?	14
8	Lecture 8: LLM Vulnerabilities and Security LLM 安全与攻击	14
8.1	Main LLM Security Risks	14
8.2	Direct vs Indirect Prompt Injection	15
8.3	Data Poisoning	15
9	Lecture 9: Agentic AI 智能体 AI	15
9.1	Definition of Agentic AI	16
9.2	Core Components	16
9.3	Workflows and Agentic Patterns	16
9.4	MCP: Model Context Protocol	16
9.5	Agentic AI Risks	16
9.6	Bounded Autonomy	17
10	Lecture 10: Hallucinations, Vibe Coding, Prompting, AI Index 幻觉、Vibe Coding、提示词与 AI 指数	17
10.1	Why LLMs Hallucinate	18
10.2	Benchmark Problem	18
10.3	Vibe Coding	18
10.4	Prompting Technique Findings	19
10.5	Evident AI Index	19
11	Homework Integration 作业整合复习	19
11.1	Homework 1: Likely Core Themes	19
11.2	Homework 2: Likely Core Themes	20
12	High-Frequency Exam Questions 高频考题	20
12.1	Short Answer Questions	20
12.2	Essay Question Structure	21
13	Key English Sentences to Memorize 必背英文句	22
14	Final One-Page Cheat Sheet 最后一页速记	23

1 Course Big Picture | 课程总览

Central Theme | 核心主线

The course is not only about how Generative AI works, but about how it can be used **safely, responsibly, and effectively** in financial services.

Main logic:

Capability → Use Case → Risk → Governance → Responsible Adoption

中文理解：这门课不是单纯讲 GenAI 技术，而是讲金融机构如何在监管、伦理、隐私、安全和治理约束下负责任地使用 GenAI。

1.1 Main Themes Across L0–L10

Theme	English Summary	中文理解
GenAI capability	LLMs can generate text, code, summaries, recommendations, and reasoning-like outputs.	LLM 能生成文本、代码、总结、建议和类似推理的输出。
Use cases in finance	Customer service, fraud detection, credit risk, compliance, reporting, marketing, personalization, financial analysis.	金融场景包括客服、反欺诈、信贷、合规、报表、营销、个性化和财务分析。
Risk	Hallucination, bias, privacy leakage, cyber risk, prompt injection, third-party risk, systemic risk.	风险包括幻觉、偏见、隐私泄露、网络攻击、提示注入、第三方风险、系统性风险。
Governance	Controls must exist across the AI life-cycle: design, data, build, validation, deployment, monitoring, retirement.	治理必须贯穿 AI 生命周期。
Regulation	OECD, BIS, IOSCO, FSB, HKMA, SFC, PCPD, MAS, EU AI Act all emphasize responsible AI.	全球和本地监管都强调负责任 AI。
Human role	In finance, humans often remain accountable and must supervise high-risk AI outputs.	金融中高风险 AI 输出通常必须有类人监督和问责。

2 Lecture 0–1: Foundations of Generative AI | GenAI 基础

2.1 What is Generative AI?

Definition | 定义

Generative AI refers to AI systems that can create new content, such as text, images, code, audio, summaries, recommendations, or synthetic data, based on patterns learned from training data.

中文：生成式 AI 是指能够基于训练数据中的模式生成新内容的 AI 系统，例如文本、图片、代码、摘要、建议或合成数据。

2.2 Traditional AI vs Generative AI vs Agentic AI

Feature	Traditional AI	Generative AI	Agentic AI
Main function	Classification, prediction, optimization	Content generation and language interaction	Goal-oriented planning and action
主要功能	分类、预测、优化	生成文本、图像、代码、对话	规划、执行、调用工具、完成目标
Autonomy	Low	Medium; usually prompt-driven	Higher; acts in loops with memory/tools
Use in finance	Credit scoring, fraud detection, risk models	Chatbots, summaries, reports, marketing copy	Workflow automation, agentic commerce, autonomous operations
Risk	Bias, model risk, opacity	Hallucination, privacy, misinformation	Compounding errors, loss of control, expanded attack surface

Exam Answer Template | 答题模板: Define Generative AI

Generative AI is a type of artificial intelligence that produces new content from learned patterns in data. In financial services, it can generate customer responses, summarize documents, draft reports, support financial analysis, and assist compliance teams. However, because outputs may be fluent but inaccurate, generative AI requires governance, validation, human oversight, and appropriate risk controls.

中文要点: GenAI 能生成内容, 但金融场景必须关注幻觉、验证、人工监督和治理。

3 Lecture 2–3: LLMs, Prompting, RAG, and Financial Use Cases | LLM、提示词、RAG 与金融应用

3.1 Large Language Models

LLM Core Idea | LLM 核心

An LLM predicts and generates sequences of tokens based on statistical patterns learned from large-scale training data.

Important implication: LLMs do not “know” facts in the human sense. They generate plausible outputs based on learned probability distributions.

中文: LLM 本质上是根据大规模训练数据学习到的统计模式来生成 token 序列, 因此可能产生看似合理但事实错误的内容。

3.2 Prompting

Prompting Element	Purpose	中文
Role	Tell the model who it should act as	设定角色
Task	Tell the model what to do	明确任务
Context	Provide background information	提供上下文

Constraints	Define rules, limits, format	设置限制
Output format	Specify table, bullet points, JSON, etc.	指定输出格式
Examples	Few-shot demonstrations	示例引导

Quick Memory | 速记: Prompt Formula | 提示词公式

Role + Task + Context + Constraints + Output Format

Example:

You are a compliance analyst in a bank. Summarize the attached regulatory update for senior management. Focus on obligations, risks, deadlines, and required actions. Use a table and avoid speculation.

3.3 RAG: Retrieval-Augmented Generation

RAG Definition | RAG 定义

Retrieval-Augmented Generation (RAG) connects an LLM to external knowledge sources. The model retrieves relevant documents and then generates an answer grounded in those documents.

中文: RAG 让 LLM 先检索外部资料，再基于资料回答，从而减少幻觉、提高可追溯性和事实准确性。

Benefit	English	中文
Grounding	Answers are based on retrieved documents.	回答基于检索资料。
Traceability	Sources can be shown to users or auditors.	可提供来源，便于审计。
Currency	External documents can be updated without retraining the model.	不必重新训练即可更新知识。
Control	Banks can restrict sources to approved internal documents.	银行可限制只使用批准资料。

Warning / Common Pitfall | 易错点: RAG is not a full solution

RAG reduces hallucination risk but does not eliminate it. The system can still retrieve irrelevant documents, misread evidence, or generate unsupported conclusions.

中文: RAG 能降低幻觉风险，但不能完全消除幻觉。

4 Lecture 4: Regulation of AI, Privacy, and More | AI 监管、隐私与规则

4.1 Why Regulate AI in Finance?

Regulatory Purpose | 金融监管目的

Financial regulation aims to:

- protect consumers and investors;
- preserve market integrity and efficiency;
- prevent fraud, money laundering, and terrorist financing;
- maintain financial stability;
- ensure institutions remain accountable.

中文：金融监管的目标是保护消费者和投资者、维护市场诚信、防止非法活动、维护金融稳定并确保机构问责。

4.2 OECD AI Principles

Principle	Meaning / 中文理解
Inclusive growth, sustainable development and well-being	AI should benefit people and society broadly. AI 应促进包容性增长、可持续发展和福祉。
Human-centred values and fairness	AI should respect human rights, privacy, equality, and non-discrimination. AI 应尊重人权、隐私、公平和非歧视。
Transparency and explainability	Stakeholders should understand AI interactions and outcomes. AI 应具有透明度和可解释性。
Robustness, security and safety	AI should be reliable, secure, safe, and resilient throughout the lifecycle. AI 应稳健、安全、可靠。
Accountability	AI actors should be responsible for proper functioning and compliance with principles. AI 参与者应对系统负责。

Exam Answer Template | 答题模板: OECD Principle Conflict

The OECD principles may conflict in practice. For example, transparency and explainability may conflict with privacy and security because disclosing too much information about model logic, data sources, or decision factors may expose sensitive personal data or system vulnerabilities. Therefore, financial institutions must balance these principles through proportional disclosure, role-based access, audit trails, and privacy-preserving explanations.

中文要点：透明度和隐私/安全可能冲突，需要分层披露、访问控制和审计。

4.3 BIS: Why Customer-Facing GenAI is High-Risk

Risk	Explanation / 中文
Mis-selling or wrong advice	Customers may rely on incorrect AI outputs. 客户可能依赖错误建议。

High validation requirements	Financial advice and decisions require strong validation. 金融建议需要高标准验证。
Unclear accountability	It may be unclear who is responsible if the model is wrong. 出错后责任可能不清。
Consumer trust and anthropomorphism	Customers may over-trust human-like AI. 客户可能把 AI 当真人信任。
Third-party dependency	Banks may rely heavily on external model providers. 银行可能过度依赖第三方模型。

Exam Answer Template | 答题模板: Customer-Facing GenAI Risk

Customer-facing GenAI is high-risk because customers may rely directly on fluent but incorrect outputs when making financial decisions. This creates risks of mis-selling, wrong advice, consumer harm, privacy leakage, and regulatory breaches. The institution remains accountable even if the model is provided by a third party. Therefore, customer-facing GenAI requires grounding, disclosure, human escalation, validation, audit logging, and strong data protection.

中文要点: 客户直接依赖 AI 输出, 风险高; 银行不能把责任外包给模型供应商。

4.4 IOSCO and FSB: Capital Markets and Financial Stability

Organization	Focus	Key Risks
IOSCO	Securities markets, intermediaries, asset managers	Governance, bias, explainability, outsourcing, malicious use, market manipulation
FSB	Global financial stability	Third-party concentration, correlated behavior, cyber fraud, model risk, disinformation

Exam Answer Template | 答题模板: AI Herding and Correlation Risk

AI can amplify herding behavior when many financial institutions use similar data sources, similar model architectures, common vendors, or similar optimization objectives. During market stress, these systems may generate similar signals at the same time, causing correlated selling, liquidity pressure, increased volatility, or even flash crashes. This is a financial stability concern because apparently independent institutions may become behaviorally correlated through shared AI infrastructure.

中文要点: 相似模型 + 相似数据 + 相似目标 = 行为趋同, 可能放大市场波动。

4.5 Hong Kong AI and GenAI Guidance

Date	Guidance	Core Message
Nov 2019	HKMA High-level Principles on AI	Governance, explainability, auditability, data quality, cybersecurity

Nov 2019	HKMA BDAI Consumer Protection	Fairness, transparency, data privacy, complaint and redress mechanisms
Jun 2024	PCPD AI Model Personal Data Protection Framework	AI governance for personal data protection
Aug 2024	HKMA GenAI Consumer Protection Circular	Customer-facing GenAI, human-in-the-loop, opt-out, disclosure
Aug 2024	HKMA/Cyberport GenAI Sandbox	Responsible innovation and supervisory feedback
Nov 2024	SFC Circular on GenAI Language Models	Senior management responsibility, model risk, cybersecurity, third-party risk

Exam Answer Template | 答题模板: Why HKMA Needed Additional GenAI Guidance

The 2019 HKMA AI principles were mainly designed for traditional predictive AI and big data analytics. Generative AI introduces additional risks because it produces open-ended natural-language outputs, may hallucinate, may be perceived as human-like, and often depends on third-party foundation models. Therefore, the HKMA needed additional GenAI guidance focusing on customer-facing use cases, human-in-the-loop controls, disclosure, opt-out options, validation, and customer data protection.

中文要点: GenAI 的开放式输出、幻觉、拟人化和第三方依赖, 使 2019 原则不够具体。

5 Lecture 5: Ethics and AI Governance | AI 伦理与治理

5.1 AI Ethics vs Responsible AI

Concept	English	中文
AI Ethics	The values and moral principles that should guide AI design and use.	AI 伦理回答 “AI 应该遵循什么价值”。
Responsible AI	The operational framework that implements ethics through controls, governance, testing, monitoring, and accountability.	负责任 AI 回答 “如何把伦理落地”。

Exam Answer Template | 答题模板: AI Ethics vs Responsible AI

AI ethics defines the values that should guide AI systems, such as fairness, transparency, privacy, accountability, safety, and human agency. Responsible AI operationalizes these values through concrete governance mechanisms, including policies, model validation, documentation, monitoring, audit trails, human oversight, and incident response. In finance, responsible AI is essential because AI outputs may affect credit, investment, insurance, fraud investigation, and customer rights.

中文要点: AI ethics 是价值, Responsible AI 是落地机制。

5.2 Responsible AI Principles

- **Fairness** （公平）
 - **Transparency** （透明）
 - **Explainability** （可解释）
 - **Accountability** （问责）
 - **Privacy and data protection** （隐私和数据保护）
- **Safety and robustness** （安全和稳健）
 - **Human agency and oversight** （人类主导和监督）
 - **Sustainability** （可持续）
 - **Societal benefit** （社会福祉）

5.3 Fairness and Bias

Bias Type	Meaning	中文
Historical bias	Training data reflects past discrimination.	历史数据包含过去歧视。
Sampling bias	Some groups are underrepresented.	某些群体样本不足。
Measurement bias	Features or labels are inaccurate proxies.	指标或标签有偏。
Algorithmic amplification	Model magnifies existing bias.	模型放大偏见。

Mitigation Stage	Example	中文
Pre-processing	Reweighting, resampling, data augmentation	训练前处理数据
In-processing	Fairness constraints, adversarial debiasing	训练中加入公平约束
Post-processing	Threshold adjustment, calibration, output review	输出后校准和审查
Governance	Bias audits, stakeholder review, monitoring dashboards	治理层面的审计和监控

Exam Answer Template | 答题模板: Bias Mitigation in Credit Scoring

Bias mitigation can be applied at multiple stages. At the pre-processing stage, a bank can rebalance or reweight training data to reduce underrepresentation. At the in-processing stage, it can include fairness constraints or adversarial debiasing during model training. At the post-processing stage, it can calibrate thresholds and review outputs to reduce disparate impact. In credit scoring, these controls help prevent discriminatory lending outcomes while preserving risk management objectives.

中文要点：贷前评分中的偏见控制可分为数据前处理、训练中约束、输出后校准和持续审计。

5.4 Transparency and Explainability

Level	Stakeholder	Explanation Needed
Level 1	General public	AI is being used; high-level purpose and limitations.

Level 2	End users	Factors that influenced a specific decision; plain-language explanation.
Level 3	Domain experts	Feature importance, uncertainty, sensitivity, alternatives.
Level 4	Technical auditors	Model architecture, training data, validation, fairness metrics, audit logs.

Exam Answer Template | 答题模板: Layered Transparency

A layered transparency approach provides different explanations to different stakeholders. End users need simple, actionable explanations, such as why a loan was declined and how they may request review. Technical auditors need detailed documentation, including model architecture, data sources, validation results, fairness metrics, and audit trails. This approach avoids overwhelming consumers while still enabling professional verification and regulatory accountability.

中文要点: 不同对象需要不同深度解释, 不能对客户和审计员给同一种解释。

5.5 Accountability and Governance

Accountability Principle | 问责原则

The financial institution remains accountable for AI outputs and customer harm, even when the AI system is built by a third-party provider.

中文: 即使模型来自第三方, 金融机构仍需对其使用结果负责。

Governance nism	Mecha-	Purpose
AI Governance Council		Cross-functional oversight: legal, risk, IT, compliance, business, ethics.
Model cards		Document model purpose, limitations, training data, performance.
Algorithmic Impact Assessment		Assess risks before deployment.
Data lineage		Track data origin and transformation.
Decision logs		Create audit trails for major decisions.
Incident response		Detect, escalate, investigate, and remediate AI failures.

Exam Answer Template | 答题模板: Air Canada Chatbot Case

The Air Canada chatbot case shows that organizations remain accountable for customer-facing AI statements. The chatbot provided incorrect information, but the company was held responsible because the chatbot was part of its official customer service channel. The case demonstrates the need for approved knowledge bases, output grounding, clear escalation paths, human review for consequential issues, and governance ownership of chatbot outputs.

中文要点: 公司不能说“是 chatbot 说的不是我说的”。部署者仍负责。

5.6 Privacy and Data Protection

Privacy Risk	Explanation / 中文
Training data memorization	LLM may reproduce sensitive information from training data. 模型可能记住并复现敏感信息。
Prompt leakage	User prompts may contain customer data. 提示词可能泄露客户数据。
Retrieval overexposure	RAG may retrieve documents beyond user entitlement. 检索可能越权。
Cross-border hosting	Data may be stored or processed in another jurisdiction. 跨境数据处理产生法律风险。
Conversation logs	Logs may retain personal or confidential information. 对话日志可能存储隐私信息。

Exam Answer Template | 答题模板: Privacy in Financial GenAI

Privacy risk is especially sensitive in finance because financial data reveals identity, income, liabilities, spending behavior, vulnerabilities, and personal relationships. GenAI may expose such information through prompts, logs, retrieval systems, or fine-tuning. Therefore, banks should apply data minimization, access controls, prompt filtering, encryption, DLP monitoring, audit logging, privacy impact assessments, and human oversight.

中文要点：金融数据极其敏感，GenAI 隐私控制必须覆盖提示词、日志、检索和第三方。

5.7 Hallucination and Model Risk

Hallucination Definition | 幻觉定义

An LLM hallucination is the generation of plausible but nonfactual, unsupported, irrelevant, or fabricated content.

中文：LLM 幻觉是指模型生成看似合理但事实错误、缺乏依据或编造的内容。

Control	Purpose
Use-case tiering	Match control intensity to business risk.
Grounding	Use approved internal sources or RAG.
Evidence visibility	Require citations, document anchors, or source links.
Confidence handling	Escalate low-confidence outputs.
Output restrictions	Prevent improvisation in regulated matters.
Human review	Require sign-off for high-impact outputs.
Monitoring	Track incidents, corrections, overrides, and user reliance.

Exam Answer Template | 答题模板: Hallucination Controls

Hallucination risk should be controlled through use-case tiering, grounding, source attribution, validation, and human review. High-risk outputs should be based on approved sources, include citations or document anchors, and be escalated when confidence is low or the case is ambiguous. For customer-facing advice, compliance interpretation, credit, claims, and suspicious activity cases, human sign-off is necessary.

中文要点：高风险金融输出必须 grounding + evidence + human review。

6 Lecture 6: Automation vs Staff Augmentation | 自动化 vs 员工增强**6.1 Automation vs Augmentation**

Concept	English	中文
Automation	AI performs tasks with minimal human involvement.	AI 自动执行任务，人工参与少。
Staff augmentation	AI supports human workers, but humans remain decision-makers.	AI 辅助员工，人类仍做最终判断。

Exam Answer Template | 答题模板: Automation vs Staff Augmentation

Automation means that AI performs tasks with limited human involvement, while staff augmentation means that AI supports employees by improving speed, analysis, drafting, and decision support. In regulated finance, augmentation is often safer because humans remain responsible for judgment, validation, and final decisions. Full automation should be limited to low-risk or tightly controlled tasks.

中文要点：金融中更偏好 augmentation，因为可保留人工判断和责任。

6.2 Common Augmentation Use Cases

Use Case	Benefit	Main Risk
Fraud detection	Detect anomalies, reduce false positives, support analysts.	Adversarial attacks, privacy, over-reliance.
Customer service chat-bot	24/7 support and personalized responses.	Wrong advice, data leakage, loss of human touch.
Credit risk assessment	Faster review, alternative data, inclusive scoring.	Bias, explainability, fairness.
Compliance reporting	Draft reports and monitor regulatory updates.	Hallucinated legal interpretation.
Personalized marketing	Micro-segmentation and dynamic content.	Privacy intrusion, manipulation.
Financial statement analysis	Extract metrics, compare trends, summarize reports.	Numerical errors, unsupported interpretations.

6.3 Summarization Challenge

Warning / Common Pitfall | 易错点: A summary is not just shorter text

A good financial summary must preserve:

- correctness of numbers;
- accuracy of statements;
- validity of sentiment;
- suitability for the target audience;
- distinction between evidence and speculation.

中文：金融总结不能只求短，还必须数字准确、语义不变、不能乱推测。

Exam Answer Template | 答题模板: GenAI in Financial Statement Analysis

GenAI can augment financial statement analysis by extracting key metrics, calculating ratios, summarizing management discussion, and identifying trends or anomalies. However, financial analysis requires strict verification because the model may misread tables, make numerical errors, or generate unsupported interpretations. Therefore, outputs should be checked against source documents, include evidence references, and be reviewed by qualified analysts before use.

中文要点：GenAI 可提高效率，但财务分析必须人工核对原始报表。

7 Lecture 7: Customer Personalization | 客户个性化

7.1 What is Customer Personalization?

Definition | 定义

Customer personalization is the tailoring of products, services, marketing, advice, and interactions to individual customers or customer segments based on demographics, behavior, preferences, life events, and financial needs.

中文：客户个性化是根据客户特征、行为、偏好、人生阶段和金融需求，定制产品、服务、营销和互动。

7.2 Personalization Use Cases in Finance

Scenario	GenAI Role	Risk
Marketing copy	Generate segment-specific messages and tones.	Overstatement, manipulation, brand inconsistency.
Financial advice	Explain products and generate tailored recommendations.	Suitability risk, wrong advice, regulatory breach.
Customer support	Provide proactive account insights and escalation.	Privacy leakage, hallucination.
Fraud detection	Personalized alerts and anomaly explanations.	False positives, adversarial manipulation.
Financial education	Tailored educational content and simulations.	Oversimplification, wrong assumptions.

7.3 Internal-facing vs External-facing GenAI

Aspect	Internal-facing	External-facing
User	Bank employees	Customers
Risk level	Usually lower	Higher
Human review	More likely before action	May be direct to customer
Main risk	Staff over-reliance, confidentiality	Customer harm, mis-selling, privacy, trust
Control need	Policies, training, review	Stronger disclosure, escalation, opt-out, monitoring

Exam Answer Template | 答题模板: GenAI Personalization Risk

GenAI can improve personalization by generating tailored marketing messages, product explanations, financial education, and proactive customer support. However, personalization in finance is risky because it may use sensitive customer data, create unsuitable recommendations, manipulate vulnerable customers, or produce misleading content. Therefore, banks need clear business objectives, data minimization, consent, human review, compliance approval, and monitoring for customer harm.

中文要点: 个性化提升体验, 但可能侵犯隐私、诱导销售或伤害弱势客户。

7.4 Why Use Button-Based Interfaces Instead of Free Prompt Editing?

Controlled Interface | 受控界面

A button-based interface limits user choices to approved categories such as product type, customer segment, and tone. This reduces prompt injection, brand inconsistency, inappropriate claims, compliance breaches, and output unpredictability.

中文: 按钮式界面能限制用户随意改 prompt, 降低合规、品牌和安全风险。

8 Lecture 8: LLM Vulnerabilities and Security | LLM 安全与攻击

8.1 Main LLM Security Risks

Risk	Meaning	中文
Prompt injection	Manipulating prompts to alter model behavior.	提示注入, 改变模型行为。
Jailbreaking	Bypassing safety rules or guardrails.	越狱, 绕过安全限制。
Sensitive information disclosure	Model reveals confidential or personal data.	泄露敏感信息。
Data poisoning	Training, fine-tuning, or embedding data is manipulated.	数据投毒。
Improper output handling	Unsafe model output is executed or trusted.	不当处理输出。

Excessive agency	LLM has too much ability to act.	过度自主权。
System prompt leakage	Hidden instructions are revealed.	系统提示泄露。
Misinformation	Model generates or spreads false content.	生成或传播错误信息。
Unbounded consumption	Excessive resource usage or denial of service.	资源消耗失控。

8.2 Direct vs Indirect Prompt Injection

Type	English	中文
Direct prompt injection	User directly enters malicious instructions.	用户直接输入恶意提示。
Indirect prompt injection	Malicious instructions are hidden in external content such as websites, files, or images.	恶意指令藏在网页、文件、图片等外部内容中。

Exam Answer Template | 答题模板: Prompt Injection

Prompt injection is an attack where an input manipulates an LLM to ignore intended instructions, reveal sensitive information, generate harmful content, or perform unauthorized actions. Direct prompt injection comes from the user prompt itself, while indirect prompt injection comes from external content retrieved or parsed by the system. Mitigations include constraining model behavior, validating input and output formats, filtering inputs and outputs, least-privilege tool access, separating trusted and untrusted content, adversarial testing, and human approval for high-risk actions.

中文要点：提示注入可直接来自用户，也可隐藏在外部资料中。控制手段包括约束、过滤、权限最小化、人审和红队测试。

8.3 Data Poisoning

Data Poisoning | 数据投毒

Data poisoning occurs when pre-training, fine-tuning, or embedding data is manipulated to introduce bias, backdoors, vulnerabilities, or harmful behavior.

中文：数据投毒是在训练、微调或向量库数据中加入恶意内容，使模型产生偏见、后门或异常行为。

Exam Answer Template | 答题模板: Why Data Poisoning is Dangerous

Data poisoning is dangerous because it can affect the model before deployment and may remain hidden until a specific trigger activates the malicious behavior. A poisoned model may appear normal in standard testing but behave differently under particular inputs, creating backdoor or sleeper-agent risks. Financial institutions should control data provenance, validate external data, monitor embedding stores, test for triggers, and apply supply-chain security controls.

中文要点：数据投毒可埋后门，普通测试未必发现。

9 Lecture 9: Agentic AI | 智能体 AI

9.1 Definition of Agentic AI

Agentic AI Definition | 定义

Agentic AI refers to AI systems that can plan, execute, and adapt through perception-reasoning-action loops, often using memory, tools, retrieval, and external systems.

中文：Agentic AI 是能规划、执行、反馈调整的 AI 系统，通常具备记忆、工具调用、检索和外部系统交互能力。

9.2 Core Components

Component	Function	中文
Planning	Break goals into subgoals and steps.	拆解目标。
Memory	Store context and previous results.	保持上下文和历史记忆。
Tools	Call APIs, databases, web search, enterprise systems.	调用工具和系统。
Reasoning engine	Select actions, evaluate results, adapt.	推理、选择和调整。
Feedback loop	Learn from outcomes and repeat.	根据反馈循环改进。

9.3 Workflows and Agentic Patterns

Workflow	When Useful	中文
Prompt chaining	Fixed sequence of subtasks with gates.	提示链，适合固定步骤。
Routing	Different categories need different prompts/tools.	路由，分流到不同任务。
Parallelization	Independent subtasks or voting for confidence.	并行处理或投票。
Orchestrator-workers	Unknown subtasks decided dynamically.	中央协调器分派任务。
Evaluator-optimizer	Iterative improvement with evaluation loop.	评估-优化循环。
Agents	Open-ended tasks where path cannot be hardcoded.	开放式智能体任务。

9.4 MCP: Model Context Protocol

MCP

The Model Context Protocol is an open standard that helps AI models connect securely and consistently with external tools, data sources, and services. It reduces fragmented integrations from many-to-many custom connections to a more standardized architecture.

中文：MCP 是连接 AI 与外部工具/数据源的开放标准，降低企业集成复杂度。

9.5 Agentic AI Risks

Risk	Explanation
Compounding errors	Mistakes accumulate over multiple steps.
Expanded attack surface	More tools, APIs, and permissions create more vulnerabilities.
Loss of control	Autonomous systems may take unexpected actions.
Accountability gap	Harder to determine responsibility across agents and tools.
Privacy and data leakage	Agents may access or retrieve sensitive data.
Cost and resource run-away	Agents may loop or consume excessive resources.

Exam Answer Template | 答题模板: Agentic AI in Finance

Agentic AI is powerful because it can plan, use tools, maintain memory, and execute multi-step workflows. In finance, it may support compliance monitoring, customer service routing, research, reporting, and operational workflows. However, higher autonomy increases risks such as compounding errors, unauthorized tool use, privacy leakage, cyber vulnerabilities, and unclear accountability. Therefore, financial institutions should apply bounded autonomy, least-privilege access, tool approval, sandbox testing, audit logs, human checkpoints, and kill-switch mechanisms.

中文要点: Agentic AI 能自动执行多步任务, 但自主性越强, 控制和责任风险越大。

9.6 Bounded Autonomy

Bounded Autonomy | 有界自主

Bounded autonomy means allowing AI agents to operate independently only within clearly defined constraints, safe envelopes, and human-controlled boundary conditions.

中文: 有界自主不是禁止 agent, 而是在明确边界、规则和人类监督下允许其自主执行。

Pillar	Meaning
Computational policies	Executable constraints defining what the agent can and cannot do.
Deontic principles	Formal ethical rules: obligations, permissions, prohibitions.
Expert system rules	Domain-specific guardrails based on human expertise.
Observability	Actions must be visible and traceable.
Intelligibility	Reasoning should be explainable to humans.
Intervenability	Humans must be able to stop, modify, or override the agent.

10 Lecture 10: Hallucinations, Vibe Coding, Prompting, AI Index | 幻觉、Vibe Coding、提示词与 AI 指数

10.1 Why LLMs Hallucinate

Core Explanation | 核心解释

LLMs compress training data into model weights through stochastic learning. This is a lossy representation of the training data. When generating answers, the model produces statistically plausible outputs, not guaranteed facts.

中文：LLM 通过随机学习把训练数据压缩进参数中，这是一种有损压缩。生成时输出的是概率上合理的内容，不保证事实正确。

Quick Memory | 速记: Generation vs Verification

A verification task is easier because the model chooses between limited options. A generation task is harder because the model must produce the answer from a much larger space.

Example:

- Verification: "Is the birthday May 11th?" Yes/No.
- Generation: "What is the birthday?" Choose from many possible dates.

10.2 Benchmark Problem

Warning / Common Pitfall | 易错点: Guessing Incentive

Many benchmarks reward correct guesses but do not reward abstention such as "I don't know". This incentivizes models to guess rather than express uncertainty.

中文：很多 benchmark 不奖励“我不知道”，导致模型倾向于猜。

Exam Answer Template | 答题模板: Why Hallucinations Persist

LLM hallucinations persist because model training is based on lossy statistical compression of incomplete data, and generation requires producing answers beyond the directly observed training examples. For non-trivial or rare facts, the model may assign probability to plausible but false outputs. Moreover, common evaluation benchmarks often reward guessing and punish abstention, encouraging models to answer even when uncertain. Mitigation requires confidence thresholds, retrieval, grounding, citations, abstention options, and human review in high-risk use cases.

中文要点：幻觉来自有损压缩、不完整知识、生成任务难度和 benchmark 鼓励猜测。

10.3 Vibe Coding

Vibe Coding Definition

Vibe coding is an AI-assisted programming style where developers describe desired outcomes in natural language and allow LLMs to generate or modify code, often with limited manual review.

中文：Vibe coding 是用自然语言描述需求，让 LLM 生成或修改代码的编程方式。

Benefit	Risk	Mitigation
Rapid prototyping	Poor code quality	Code review
Lower skill barrier	Security vulnerabilities	Security testing
Higher productivity	Technical debt	Debt tracking tools

Fast iteration

Maintainability crisis

Architecture standards

Exam Answer Template | 答题模板: Vibe Coding Risk

Vibe coding can accelerate prototyping and reduce repetitive programming work, but it can also create technical debt, inconsistent architecture, security vulnerabilities, and poorly documented code. In financial institutions, AI-generated code should not be deployed into critical systems without human code review, security testing, dependency checks, documentation, and architectural governance.

中文要点: Vibe coding 快, 但会快速制造技术债, 金融系统必须严格审查。

10.4 Prompting Technique Findings**Prompting Research Takeaway**

Prompt tweaks such as politeness or commanding language may affect individual questions, but effects are inconsistent and often disappear at aggregate level. Model characteristics, formatting, context, and repeated testing matter more than universal prompting tricks.

中文: 提示词技巧没有万能公式。模型本身、格式、上下文和重复测试更重要。

10.5 Evident AI Index

Pillar	Weight	Meaning
Talent	45%	AI and data employees, capability, hiring, upskilling.
Innovation	30%	Research, patents, investments, partnerships, open source.
Leadership	15%	AI narrative, executive positioning, communication.
Transparency	10%	Responsible AI activities, governance, public disclosure.

11 Homework Integration | 作业整合复习**11.1 Homework 1: Likely Core Themes****Homework 1 Focus | 作业 1 可能核心**

Homework 1 likely focused on applying GenAI to financial use cases, evaluating benefits, limitations, and risk controls. The expected answer style is practical: define the use case, identify GenAI contribution, discuss risks, and propose governance.

中文: 作业 1 重点通常是金融 GenAI 应用分析: 场景、收益、风险、控制。

Exam Answer Template | 答题模板: Generic Use Case Answer Structure

A strong GenAI use-case answer should include:

1. **Business problem:** What pain point does the institution face?
2. **GenAI application:** What does the model generate or support?
3. **Benefits:** Efficiency, personalization, accuracy, productivity, scalability.
4. **Risks:** Hallucination, bias, privacy, cybersecurity, accountability, third-party risk.
5. **Controls:** Human review, validation, RAG, access controls, monitoring, audit logs, incident response.

中文：答应用题时按“问题-应用-收益-风险-控制”结构写。

11.2 Homework 2: Likely Core Themes**Homework 2 Focus | 作业 2 核心**

Homework 2 strongly aligns with regulation, governance, ethics, privacy, consumer protection, hallucination, and human oversight.

中文：作业 2 与 L4-L6 关系最强，重点是监管、伦理、隐私、治理和幻觉控制。

Likely Question	Core Answer
Why HKMA issued GenAI guidance	GenAI creates open-ended outputs, hallucinations, anthropomorphism, third-party dependency, and customer-facing harm.
OECD principle conflict	Transparency may conflict with privacy/security; innovation may conflict with consumer protection.
BIS customer-facing risk	Mis-selling, wrong advice, accountability, validation, third-party reliance.
IOSCO herding	Similar AI systems can cause correlated market behavior.
FSB financial stability	Third-party concentration, market correlation, cyber fraud, model risk, disinformation.
Bias mitigation	Pre-processing, in-processing, post-processing, governance controls.
Layered transparency	Different explanations for public, customers, experts, auditors.
Accountability case	Deployer remains responsible for AI outputs.
Privacy oversight	Human review, access control, PIA, DLP, audit logs.
Hallucination controls	Grounding, citations, confidence thresholds, human review.

12 High-Frequency Exam Questions | 高频考题**12.1 Short Answer Questions**

1. Define Generative AI and explain one financial services use case.

2. Compare traditional AI, GenAI, and agentic AI.
3. Explain why RAG can reduce hallucination risk but cannot eliminate it.
4. Why is customer-facing GenAI more risky than internal-facing GenAI?
5. Explain the OECD AI principles and give one example of conflict between them.
6. What is herding behavior and how can AI amplify it in financial markets?
7. How can similar AI models increase financial stability risk?
8. Explain bias sources and bias mitigation methods in credit scoring.
9. What is layered transparency and why is it useful?
10. What does the Air Canada chatbot case teach about accountability?
11. Explain privacy risks of GenAI in financial services.
12. What safeguards can reduce hallucination risk?
13. Compare automation and staff augmentation.
14. Why is GenAI summarization risky in financial reporting?
15. Explain prompt injection and mitigation strategies.
16. What is data poisoning and why is it difficult to detect?
17. Define agentic AI and explain its core components.
18. What is bounded autonomy and why is it important?
19. What is vibe coding and what are its risks?
20. Why can prompt engineering results be inconsistent?

12.2 Essay Question Structure

Exam Answer Template | 答题模板: General Essay Formula

For most essay questions, use this structure:

1. **Definition:** Define the concept clearly.
2. **Financial context:** Explain why it matters in finance.
3. **Benefits:** Identify business or operational value.
4. **Risks:** Discuss technical, ethical, legal, and systemic risks.
5. **Controls:** Propose governance, human oversight, validation, monitoring, and incident response.
6. **Conclusion:** Emphasize responsible adoption.

中文: 大题万能结构: 定义 → 金融意义 → 收益 → 风险 → 控制 → 结论。

13 Key English Sentences to Memorize | 必背英文句

Quick Memory | 速记: Core Sentences

1. Financial regulation aims to protect consumers, preserve market integrity, prevent illicit activity, and maintain financial stability.
2. Generative AI is powerful because it can generate language-based outputs at scale, but it is risky because outputs may be fluent, persuasive, and false.
3. Responsible AI operationalizes ethical principles through governance, controls, documentation, monitoring, and human oversight.
4. Customer-facing GenAI is high-risk because customers may rely directly on model-generated outputs when making financial decisions.
5. Outsourcing the technology does not outsource the responsibility.
6. A layered transparency approach provides different explanations to different stakeholders according to their needs.
7. Meaningful human oversight requires authority, competence, time, and information to challenge AI outputs.
8. RAG can improve grounding and traceability, but it does not eliminate hallucination risk.
9. AI can amplify herding behavior when institutions use similar data, models, vendors, or optimization objectives.
10. Staff augmentation is often preferable to full automation in regulated finance because humans remain responsible for final decisions.
11. Prompt injection manipulates model behavior through malicious or unintended instructions.
12. Agentic AI increases capability but also increases the risk of compounding errors and loss of control.
13. Bounded autonomy allows agents to operate efficiently within clearly defined constraints.
14. Vibe coding accelerates software creation but can also accelerate technical debt.
15. Responsible adoption means not using AI everywhere, but using AI where risks are understood, controls are effective, and accountability is clear.

14 Final One-Page Cheat Sheet | 最后一页速记

If You Only Remember One Framework

For any GenAI in finance question, answer with:

Use Case → Benefit → Risk → Control → Accountability

Example:

In customer service, GenAI can improve 24/7 support and personalization. However, it creates risks of hallucination, wrong advice, privacy leakage, and customer harm. Controls include RAG grounding, approved knowledge bases, human escalation, disclosure, audit logging, monitoring, and incident response. The bank remains accountable for outputs even if the model is provided by a third party.

Topic	Must Remember
OECD	Fairness, transparency, robustness, accountability, human-centred values.
BIS	Customer-facing GenAI is high-risk.
IOSCO	AI risks in capital markets include malicious use, model/data risk, outsourcing, human-AI interaction, systemic risk.
FSB	Financial stability risks: third-party concentration, correlations, cyber fraud, model risk, disinformation.
HKMA	2019 AI principles + 2024 GenAI consumer protection.
SFC	Senior management, model risk, cybersecurity, third-party risk.
PCPD	Personal data protection and human oversight.
Ethics	Fairness, transparency, accountability, privacy, safety, human agency.
Hallucination	Plausible but false output; control with grounding, citations, confidence, human review.
Security	Prompt injection, jailbreaking, data poisoning, least privilege, guardrails.
Agentic AI	Planning, memory, tools, reasoning, feedback loops; bounded autonomy.
Augmentation	Safer than automation in high-risk finance.

End of Revision Guide